

CEG 4750/6750 (Information Security) Homework # 5

Student Name: _____ Bhuwan Pandey _____

Wright UID: _____ U01155118 _____

Undergraduate/Graduate: _____ Graduate _____

Question 1 (10 points).

In class we learned a fundamental set of cryptography systems. For the duration of these questions presume you have access to a small, but trusted source of information (i.e., a public website).

Discuss how you would apply them to the following situations:

1. Someone who has never communicated with you in the past needs to send you a secret message over an insecure channel. How can he create it so that only you can read it?

Answer: Since we have never communicated before, there is no shared secret between us. I would use public key encryption to handle this. I would publish my public key on a trusted public website. The sender can grab it from there, encrypt the message with it, and send it over the insecure channel. Since only my private key can decrypt it, nobody intercepting the message can read it.

2. You need to receive orders over an insecure channel from your boss. How can you make sure his message's integrity has been preserved?

Answer: In this case I am not worried about secrecy. I need to know the message actually came from my boss and wasn't modified in transit. My boss would sign the message using his private key, creating a digital signature. I would look up his public key on the trusted website and use it to verify the signature. If it checks out, I know the message is authentic and intact.

Question 2 (10 points) What is the difference between a message authentication code and a one-way hash function?

Answer: Well, they both produce a fixed length output from a message, but they are used for different things.

A one way hash function takes a message and produces a digest with no key involved. Anyone can compute it. and it useful for checking whether data has been altered, but it cannot tell anything about who sent it.

A message authentication code also produces a fixed length value from a message, but it requires a secret key shared between the two parties. So the output depends on both the message and that key. This means a message authentication code gives me both integrity and authentication. Meaning, i can confirm the message was not tampered with and that it came from someone who holds the key. A hash only gives me the first part.

Question 3 (10 points). List possible ways to distribute secret keys to two communicating parties.

Answer: Below are the few approaches exist for distributing secret keys between two parties:

- Physical delivery: one party selects a key and hands it over in person or through a trusted courier. Not practical at scale, but it works.
- Using an existing shared key: if the two parties already share an older key, they can use it to encrypt and transmit a new one securely.
- Key Distribution Center: a trusted third party shares a unique master key with each user. When two users need to communicate, it generates a session key and delivers it to both, encrypted under their respective master keys.
- Public key encryption one party encrypts the secret key using the other's public key and sends it over. No prior shared secret is needed.
- Diffie-Hellman key exchange: both parties independently compute the same shared secret over a public channel without ever transmitting the key itself.

Question 4 (10 points). List four general categories of schemes for the distribution of public keys.

Answer: The four general categories for public key distribution are:

- Public announcement a user simply broadcasts their public key to others directly. It is easy but unreliable since anyone can forge a key and claim it belongs to someone else.
- Publicly available directory: a trusted authority maintains a directory of public keys that anyone can query. More reliable, but the directory itself has to be kept secure and trustworthy.
- Public key authority: users request public keys directly from a central authority, which responds with a signed reply. It is more secure, but every lookup goes through that one authority, making it a potential headache.
- Public key certificates: a Certificate Authority (CA) issues signed certificates that bind a public key to an identity. These can be verified offline without contacting anyone, making this the most scalable and practical option.

Question 5 (10 points). What is a public key certificate?

Answer: A public key certificate is a signed data structure that ties a public key to a specific identity. It is issued by a trusted Certificate Authority (CA) and contains things like the owner's name, their public key, the validity period, and the CA's digital signature over all of it. Anyone who trusts that CA can verify the certificate independently without having to contact a central server. It is the standard way of confirming that a public key actually belongs to the person or entity claiming it.

Question 6 (15 points) Consider a Diffie-Hellman scheme with a common prime $q=11$, and a primitive root $g=2$.

(1) Show that 2 is a primitive root of 11.

Answer: A primitive root g of a prime q needs to generate every nonzero value from 1 to $q-1$ through successive powers mod q . Computing powers of 2 mod 11:

$$\begin{aligned}
2^1 \bmod 11 &= 2 \\
2^2 \bmod 11 &= 4 \\
2^3 \bmod 11 &= 8 \\
2^4 \bmod 11 &= 5 \\
2^5 \bmod 11 &= 10 \\
2^6 \bmod 11 &= 9 \\
2^7 \bmod 11 &= 7 \\
2^8 \bmod 11 &= 3 \\
2^9 \bmod 11 &= 6 \\
2^{10} \bmod 11 &= 1
\end{aligned}$$

All values 1 through 10 appear exactly once, so 2 is a primitive root of 11.

(2) If user A has public key $Y_a=9$, what is A's private key X_a ?

Answer: I need to solve $2^{X_a} \bmod 11 = 9$. From the table above, $2^6 \bmod 11 = 9$, so $X_a = 6$.

(3) If user B has public key $Y_b=3$, what is the shared secret key K , shared with A?

Answer:

$$K = Y_b^{X_a} \bmod 11 = 3^6 \bmod 11$$

$$3^1=3, 3^2=9, 3^3=5, 3^4=4, 3^5=1, 3^6=3$$

So $K = 3$.

To verify from B's side: $Y_b = 3 = 2^8 \bmod 11$, so $X_b = 8$. Then $K = Y_a^{X_b} = 9^8 \bmod 11$. Since $9 = 2^6$, this is $2^{48} \bmod 11$. $48 \bmod 10 = 8$, so $2^8 \bmod 11 = 3$.

Question 7 (20 points, graduate students only) (1) Consider the Davies and Price hash code scheme described in Section 11.4 and assume that DES is used as the encryption algorithm:

$$H_i = E_{M_i}[H_{i-1}] \oplus H_{i-1}$$

And recall the complementarity property of DES: If $Y = \text{DES}_K(X)$, then $Y' = \text{DES}_{K'}(X')$. Use this property to show how a message consisting of blocks $M_1, M_2, \dots, M_N$ can be altered without altering its hash code.

Answer: DES has the complementarity property: if $Y = E_K(X)$, then $Y' = E_{K'}(X')$. Flipping all bits in both the key and plaintext flips all bits in the ciphertext output. If I replace every message block M_i with its complement M_i' , and start with H_0' instead of H_0 , then at each step:

$$H_{i_new} = E_{M_i'}[H_{i-1}'] \oplus H_{i-1}'$$

By complementarity, $E_{M_i'}[H_{i-1}'] = (E_{M_i}[H_{i-1}])'$. And since $A' \oplus B' = A \oplus B$ for any bits A, B :

$$H_{i_new} = H_{i_old}'$$

The complement carries forward through every block, so the final hash becomes H_N' . This is predictable and more importantly, I can construct pairs of blocks where the complement effect cancels itself out, producing a modified message that results in the exact same final hash as the original. That is a collision, which breaks the scheme.

(2) Show that a similar attack will succeed against the scheme proposed in [MEYE88]:

$$H_i = E_{H_{i-1}}[M_i] \oplus M_i$$

Answer: The same property applies here also. Replacing M_i with M_i' and using H_{i-1}' as the chaining value:

$$H_{i_new} = E_{H_{i-1}'}[M_i'] \oplus M_i'$$

By complementarity: $E_{H_{i-1}'}[M_i'] = (E_{H_{i-1}}[M_i])'$. So:

$$H_{i_new} = (E_{H_{i-1}}[M_i])' \oplus M_i' = (E_{H_{i-1}}[M_i] \oplus M_i)' = H_i'$$

The complement propagates the same way as before. By replacing all message blocks with their complements and adjusting the IV, I get a fully predictable altered hash. Meaning, the same type of attack works here too, and this scheme has the same fundamental weakness.